Laboratorios ECAR S.A.

Sistema de Gestión de Equipos e Inspecciones

Documentación técnica

Arquitectura, datos, API, seguridad, despliegue y mantenimiento

Documento	Documentación técnica
Versión	1.2
Fecha	11 de noviembre de 2026
Cliente	Laboratorios ECAR S.A.
Elaborado por	Equipo de desarrollo del proyecto ECAR

Información del documento

Campo	Valor
Documento	Documentación técnica
Sistema	Sistema de Gestión de Equipos e Inspecciones (versión 1.0)
Cliente	Laboratorios ECAR S.A.
Dirigido a	Área de TI de ECAR, administradores de servidores y bases de datos, desarrolladores que mantengan el sistema y responsables de validación
Código de referencia	Carpeta «Cliente PROD» (solución ECAR.AuditoriaEquipos.slnx)
Documentos relacionados	Documentación de gestión e inicio del proyecto · Manual de usuario · README.md de la solución

Control de versiones

Versión	Fecha	Descripción	Elaboró
1.0	08/11/2026	Primera versión para la entrega final del proyecto.	Equipo de desarrollo
1.1	10/11/2026	Inicio de sesión con SGI.Identity: integración, estados, roles por grupos, nombre del firmante, configuración, despliegue, operación y pruebas. Logo de ECAR en los PDF.	Equipo de desarrollo
1.2	11/11/2026	La carpeta de la entrega se llama «Cliente PROD». Sin la URL de SGI.Identity (repositorio público).	Equipo de desarrollo

Contenido

1. Introducción 4
1.1. Propósito y alcance 4
1.2. Resumen del sistema 4
1.3. Convenciones 4
2. Arquitectura 5
2.1. Vista general 5
2.2. Proyectos de la solución 5
2.3. Tecnologías y versiones 6
2.4. Flujo de una petición 6
3. Backend: ECAR.API 7
3.1. Canalización de arranque 7
3.2. Convenciones de la API 7
3.3. Servicios principales 8
4. Seguridad 9
4.1. Autenticación 9
4.2. Integración con SGI.Identity 9
4.3. Autorización por roles 10
4.4. Protección de las comunicaciones y del navegador 11
4.5. Secretos 11
5. Firma electrónica e integridad (CFR 21 Parte 11) 12
5.1. Firma de una inspección 12
5.2. Sello HMAC-SHA256 12
5.3. Verificación 13
5.4. Inmutabilidad y ciclo de vida 14
6. Auditoría 15
6.1. Contenido de cada fila 15
6.2. Acciones registradas 15
6.3. Protección 15
7. Modelo de datos 16
7.1. Estados y valores controlados 17
7.2. Diccionario de datos 17
8. API REST 23
8.1. Rutas por controlador 23
9. Cliente: ECAR.Client (Blazor WebAssembly) 28

9.1. Estructura 28
9.2. Interoperabilidad con JavaScript 28
9.3. Dirección del API y sesión 28
9.4. Diseño y adaptación a pantallas 29
10. Procesos clave 30
10.1. Inspección 30
10.2. Novedades y notificaciones 30
10.3. Reportes y tablero 30
10.4. Código QR 30
10.5. Evidencias 30
11. Configuración 31
12. Instalación y despliegue 33
12.1. Requisitos del servidor 33
12.2. Compilación y publicación 33
12.3. Configuración en IIS 34
12.4. Base de datos 34
12.5. Verificación después del despliegue 34
13. Operación y mantenimiento 35
13.1. Copias de seguridad 35
13.2. Registros y monitoreo 35
13.3. Rotación de claves 35
13.4. Cambios en el modelo de datos 35
13.5. Dependencias y licencias 35
13.6. Datos heredados sin uso 36
14. Pruebas y calidad 37
Anexo A. Comandos útiles 38
Anexo B. Glosario técnico 39

1. Introducción

1.1. Propósito y alcance

Este documento describe cómo está construido el Sistema de Gestión de Equipos e Inspecciones de Laboratorios ECAR S.A.: su arquitectura, el modelo de datos, la API REST, los mecanismos de seguridad, firma electrónica e integridad que soportan el cumplimiento de CFR 21 Parte 11 y ALCOA+, y cómo instalarlo, configurarlo, operarlo y mantenerlo. Corresponde al código entregado en la carpeta «Cliente PROD».

1.2. Resumen del sistema

- Aplicación web de una sola página (Blazor WebAssembly) que consume una API REST (ASP.NET Core, .NET 10) con base de datos SQL Server.
- Inicio de sesión con SGI.Identity, el servicio corporativo de autenticación de ECAR: valida la contraseña y envía el nombre y los grupos de cada persona; el sistema crea su propia sesión (JWT) y asigna los roles según esos grupos.
- Cuatro roles (Administrador, Operador, Estándar y Supervisor) con autorización en el servidor.
- Inventario de equipos con código QR, checklists versionados, inspecciones con fotografías y firma electrónica sellada con HMAC-SHA256, novedades que se resuelven con firma y avisan por correo, tablero, cinco reportes en PDF y Excel, y auditoría encadenada e inalterable.
- Sin borrado físico de inspecciones, novedades ni evidencias: se anulan o retiran con motivo y queda constancia.

1.3. Convenciones

- Las fechas se guardan en UTC y se muestran en hora de Colombia (UTC−5, sin horario de verano).
- Las rutas del API se escriben relativas a la raíz del sitio, por ejemplo `/api/equipos`.
- Los nombres de clases, archivos y claves de configuración se escriben en `fuente monoespaciada`.

2. Arquitectura

2.1. Vista general

La solución sigue una arquitectura cliente-servidor en capas. El cliente se descarga al navegador y se ejecuta allí; todas las reglas de negocio, la seguridad y el acceso a los datos están en el API.

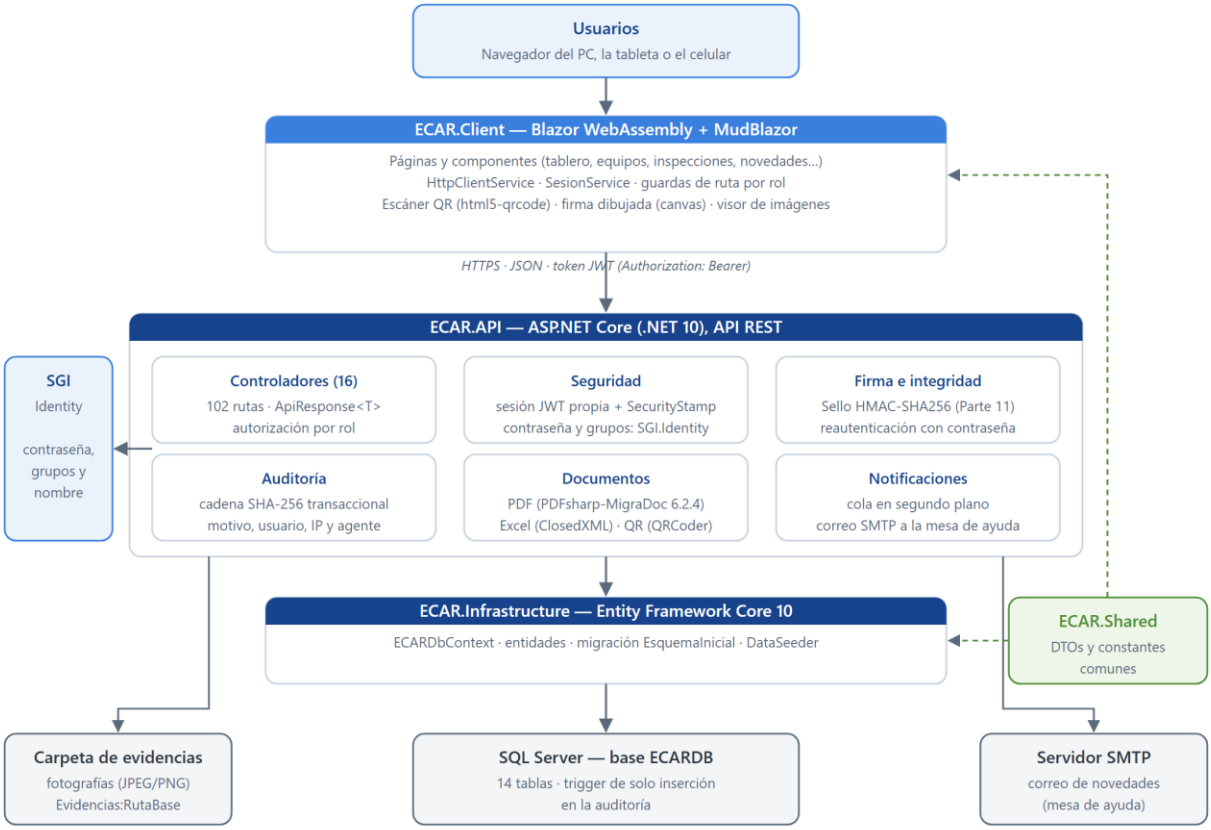


Figura 1. Arquitectura lógica de la solución

2.2. Proyectos de la solución

Tabla 1. Proyectos de la solución ECAR.AuditoriaEquipos.slnx

Proyecto	Tipo	Responsabilidad
`ECAR.API`	ASP.NET Core Web API	Controladores REST, integración con SGI.Identity, sesión JWT, autorización por rol, servicios de negocio (inspecciones, firma, integridad, reportes, notificaciones, evidencias), arranque y migración de la base.
`ECAR.Client`	Blazor WebAssembly	Interfaz de usuario con MudBlazor: páginas, componentes, servicios HTTP, sesión, guardas de ruta e interoperabilidad con JavaScript (cámara, firma, impresión).
`ECAR.Infrastructure`	Biblioteca de clases	`ECARDbContext` (Entity Framework Core), entidades, migraciones, auditoría transaccional y `DataSeeder`.
`ECAR.Shared`	Biblioteca de clases	DTOs y constantes compartidas por el API y el cliente: estados, roles, criticidades, sedes, tipos de respuesta, `ApiResponse<T>` y `PagedResultDto<T>`.

2.3. Tecnologías y versiones

Tabla 2. Tecnologías, versiones y licencias

Componente	Tecnología	Versión	Licencia
Plataforma	.NET (SDK y runtime)	10	MIT
API	ASP.NET Core, Microsoft.AspNetCore.OpenApi, Scalar.AspNetCore (documentación, solo en desarrollo)	10.0 · 10.0.10 · 2.16.20	MIT
Datos	Entity Framework Core SQL Server, Design y Tools	10.0.11	MIT
Base de datos	Microsoft SQL Server (el SRS v1.1 indica SQL Server 2022; probado con SQL Server Express)	2022	Comercial / Express
Autenticación	Microsoft.AspNetCore.Authentication.JwtBearer · System.IdentityModel.Tokens.Jwt	10.0.11 · 8.22.0	MIT
Identidad	SGI.Identity (servicio de ECAR), por HTTP	Contrato v1.0	Interno de ECAR
Cuentas locales	BCrypt.Net-Next	4.2.0	MIT
Directorio Activo	System.DirectoryServices.Protocols (modo alternativo)	10.0.1	MIT
PDF	PDFsharp-MigraDoc	6.2.4 (última MIT; no actualizar a 6.5+, que es AGPL)	MIT
Excel	ClosedXML	0.105.1	MIT
Código QR	QRCoder	1.8.0	MIT
Criptografía	System.Security.Cryptography.Pkcs	10.0.13	MIT
Cliente	Microsoft.AspNetCore.Components.WebAssembly · MudBlazor	10.0.10 · 9.8.0	MIT
Lector QR (navegador)	html5-qrcode (servido desde el propio cliente, sin CDN)	2.3.8	Apache-2.0

2.4. Flujo de una petición

1. El navegador descarga el cliente Blazor (archivos estáticos) y lo ejecuta.
2. El usuario inicia sesión: `POST /api/auth/login`. El API valida la contraseña con SGI.Identity, asigna los roles según los grupos que devuelve y entrega un token JWT propio, que el cliente guarda en el navegador.
3. Cada petición al API lleva el token en la cabecera `Authorization: Bearer`. El API valida la firma, la vigencia y el sello de seguridad del usuario (`ecar_sello`), y luego el rol exigido por la ruta.
4. El controlador valida los datos (DTO), aplica las reglas de negocio y guarda los cambios con `ECARDbContext`. La auditoría se escribe en la misma transacción.
5. La respuesta siempre es un `ApiResponse<T>` con `success`, `message`, `data` y, si hay varios errores de validación, `errors`.

3. Backend: ECAR.API

3.1. Canalización de arranque

`Program.cs` registra los servicios y configura, en este orden: el formato de errores de validación, Entity Framework con consultas divididas (`SplitQuery`), la autenticación JWT con validación del sello de seguridad, las opciones validadas al arrancar (autenticación, SGI.Identity, Directorio Activo, seguridad de cuentas y firma), el cliente HTTP de SGI.Identity (con el encabezado `Authorization` oculto en los registros), el correo, el almacenamiento de evidencias y CORS. Después aplica HSTS (fuera de desarrollo), la redirección a HTTPS, las cabeceras de seguridad, CORS, autenticación y autorización; ejecuta `Database.MigrateAsync()` y `DataSeeder` y publica los controladores.

> **Importante:** El API no arranca si faltan la cadena de conexión, `JWT:Secret` (32 caracteres o más) o `Firma:ClaveHmac` (32 caracteres o más). En el modo `SgiIdentity` tampoco arranca si faltan la URL, el `ClientId` o el `ClientSecret` de SGI.Identity, si la URL es `http://` sin `SgiIdentity:PermitirHttp` o si la tabla de grupos nombra un rol que no existe. El mensaje dice qué falta.

3.2. Convenciones de la API

Tabla 3. Convenciones de la API

Tema	Convención
Respuesta	`ApiResponse<T>` en todas las rutas; los listados devuelven `PagedResultDto<T>` (`data`, `totalCount`, `page`, `pageSize`, `totalPages`).
Paginación	`page` y `pageSize` (máximo 100 por página).
400	Datos inválidos, con el mensaje en español y la lista `errors` cuando hay varios. También contraseña errónea al firmar (nunca 401, porque el cliente trata el 401 como sesión vencida).
401 / 403	Sin sesión o token inválido / rol insuficiente o recurso ajeno. En el inicio de sesión, 401 es usuario o contraseña incorrectos, y 403, que no se puede entrar todavía (contraseña vencida o inicial pendiente, con la acción y un pase; cuenta inactiva; sin grupo con rol).
404 / 405	Recurso inexistente / método no permitido (no existe `DELETE` de inspecciones, novedades ni evidencias).
409	El estado no permite la acción (firmar dos veces, modificar una inspección firmada, borrar un catálogo en uso, checklist duplicado).
423	Cuenta bloqueada (por SGI.Identity o, en las cuentas locales, por intentos fallidos en ECAR), al iniciar sesión o al firmar.
503	SGI.Identity no responde o rechaza a ECAR como aplicación consumidora (al iniciar sesión, al firmar o al cambiar la contraseña).
Motivo	Obligatorio, de 10 a 500 caracteres, en ediciones, desactivaciones, anulaciones, retiros y desbloqueos (`MotivoDto` o `?motivo=`). Se guarda en la auditoría.
DTOs	Los controladores reciben y devuelven DTOs de `ECAR.Shared`, nunca entidades.
Fechas	Las fechas de registro las pone el servidor (UTC); el cliente no las fija.

3.3. Servicios principales

Tabla 4. Servicios del API

Servicio	Función
`AuthService`	Inicio de sesión y confirmación de identidad para firmar. Modo vigente: SGI.Identity (alta automática, nombre y roles según el servicio). Alternativos: contraseña local (BCrypt), Directorio Activo (`LdapActiveDirectoryAuthService`) o híbrido. Emite el JWT y registra los eventos de acceso en la auditoría.
`SgiIdentityClient`	Cliente HTTP de SGI.Identity: inicio de sesión, contraseña inicial y cambio de contraseña, con `Authorization: Basic`. Decide por `status` e `isAuthenticated` (o `success`), nunca por el texto del mensaje; una respuesta que no reconoce cuenta como «no disponible». No registra el cuerpo, las contraseñas ni las credenciales.
`MapeoGruposRoles` / `PaseCambioPassword`	Traducción de los grupos de SGI.Identity a los roles de ECAR (`SgiIdentity:Grupos`) y pase de 10 minutos para las pantallas de cambio y activación (JWT con otra audiencia: no sirve como sesión).
`SelloSeguridad`	Valida en cada petición que el `SecurityStamp` del token coincida con el del usuario y que siga activo.
`InspeccionService`	Inicio, guardado de respuestas, reglas de cierre y creación de novedades.
`VerificadorIntegridad` / `FirmaInspeccion`	Cálculo y verificación de los sellos HMAC-SHA256 de inspecciones y novedades.
`AccesoInspeccion`	Decide quién puede leer una inspección (propietario, Estándar, Supervisor, Administrador).
`ReporteService` / `ExportadorTabla` / `AjusteTexto`	Consultas de los reportes y su exportación a PDF (A4 horizontal, columnas ajustadas al contenido) y Excel.
`RegistroInspeccionPdf` / `TableroPdf`	PDF del registro de una inspección y del tablero. Los tres tipos de PDF se arman con `ExportadorTabla.Documento`: el logo de ECAR en el encabezado de cada página (1,6 cm; es `ECAR.Client/wwwroot/images/logo-ecar.png`, incrustado en el API como `ECAR.API.logo-ecar.png`) y el pie con filtros, autor, fecha y página.
`ColaNotificaciones` / `EnvioNotificacionesService` / `NotificacionNovedades`	Cola en memoria de inspecciones con novedades y servicio en segundo plano que envía un correo por inspección (o guarda un .eml si no hay credenciales).
`EvidenciaStorageDisco`	Guarda las fotografías en `{RutaBase}/{año}/{mes}/{idInspección}/{GUID}.jpg|png` y las sirve.
`ContextoAuditoriaHttp` / `MotivoCambio` / `AutorAuditoria`	Aportan a la auditoría el usuario («Nombre (usuario)»), la IP, el navegador y el motivo de cada cambio. `AutorAuditoria` firma como «usuario (SGI.Identity)» los cambios que hace el inicio de sesión antes de que haya token.
`PoliticaPasswords`	Valida la contraseña del alta de cuentas locales (fuera del modo SgiIdentity).

4. Seguridad

4.1. Autenticación

- **Modo vigente** (`ECARAuthentication:Mode` = `SgiIdentity`): la contraseña la valida SGI.Identity, el servicio corporativo de ECAR, que a su vez la comprueba contra el Directorio Activo o contra sus propias cuentas. Ese servicio también bloquea las cuentas, hace caducar las contraseñas y las cambia; ECAR no guarda las contraseñas de esos usuarios. El detalle está en la sección siguiente.
- **Token JWT** propio, firmado con HMAC-SHA256 (`JWT:Secret`), emisor y audiencia configurables, vigencia de `JWT:ExpirationHours` (8 horas) y sin tolerancia de reloj. Lleva el id, correo, nombre, usuario (`ecar_usuario`), uno o varios roles y el sello `ecar_sello`. La respuesta de SGI.Identity no es una sesión: ECAR crea la suya (guía de integración §5.2).
- **Revocación inmediata:** al desactivar un usuario, o cuando SGI.Identity le cambia los grupos y con ellos los roles, cambia su `SecurityStamp` y todos sus tokens dejan de valer en la siguiente petición.
- **Cuentas locales:** las cuentas con contraseña guardada en ECAR (`admin@ecar.com`) entran con BCrypt mientras `SgiIdentity:PermitirCuentasLocales` sea true, como acceso de respaldo. Solo para ellas sigue el bloqueo de ECAR: 5 intentos fallidos (`Seguridad:MaxIntentosFallidos`) bloquean la cuenta 30 minutos (`Seguridad:MinutosBloqueo`), con 423, y el Administrador desbloquea con motivo.
- **Otros modos:** `Local` (solo contraseñas BCrypt), `ActiveDirectory` (LDAP con TLS) e `Hybrid` siguen en el código como contingencia; no se usan con SGI.Identity.
- **Inactividad:** el cliente cierra la sesión tras 15 minutos sin actividad (`Seguridad:MinutosInactividad`, que publica `GET /api/auth/politica` junto con el modo de autenticación).

4.2. Integración con SGI.Identity

El API llama a SGI.Identity desde el servidor (`SgiIdentityClient`), según su guía de integración y su documento de arquitectura v1.0. Cada llamada se identifica con `Authorization: Basic base64(ClientId:ClientSecret)` y lleva los datos del usuario en el cuerpo JSON. Las credenciales de ECAR nunca llegan al navegador ni a los registros.

Tabla 5. Operaciones de SGI.Identity que consume el sistema

Operación de SGI.Identity	La usa ECAR en
`POST api/authentication/login`	El inicio de sesión (`POST /api/auth/login`) y la confirmación de identidad de cada firma.
`POST api/authentication/change-password`	`POST /api/auth/cambiar-password` (pantalla «Cambiar contraseña»).
`POST api/authentication/initial-password`	`POST /api/auth/password-inicial` (pantalla «Activar su cuenta»).

Tabla 6. Estados de SGI.Identity y respuesta del sistema

Respuesta de SGI.Identity	Respuesta del sistema
`Authenticated` con `isAuthenticated` = true	Crea o actualiza el usuario y entrega la sesión (200). Sin un grupo con rol en ECAR: 403.
`InvalidCredentials`	401 en el inicio de sesión; 400 en la firma (nunca 401: el cliente lo trataría como sesión vencida).
`UserLocked`	423 con el mensaje de SGI.Identity.
`PasswordExpired` / `RequiresPasswordChange`	403 con `AccionRequerida` = `CambiarPassword` y un pase: el cliente abre «Cambiar contraseña».
`RequiresInitialPasswordSetup`	403 con `AccionRequerida` = `ConfigurarPasswordInicial` y un pase: el cliente abre «Activar su cuenta».
`UserInactive` / `UserWithoutGroups`	403 con su mensaje.
401 o 403 sin estado	SGI.Identity rechazó a ECAR (ClientId o ClientSecret): 503 y un error en el registro, sin las credenciales.
Sin respuesta, tiempo agotado, 5xx o estado desconocido	503 «servicio no disponible». Nunca se deja entrar ni se firma.

- **Usuario y nombre:** la cuenta de ECAR se enlaza por el usuario de SGI.Identity (`Usuarios.UsuarioAD`). El primer ingreso la crea (`SgiIdentity:CrearUsuariosAlEntrar`) con el nombre que envía el servicio (`displayName`) y un correo provisional (`usuario@sgi.local`; el sistema identifica a las personas por su usuario). El nombre se actualiza en cada inicio de sesión y es el que queda en las firmas; si el servicio no lo envía, se conserva el que había.
- **Roles:** salen de `SgiIdentity:Grupos` (grupo → rol) y se actualizan en cada inicio de sesión. Un usuario registrado puede escribir su correo en lugar de su usuario: el API envía a SGI.Identity su usuario.
- **Cambio y activación:** las pantallas solo se abren con el pase que entrega el inicio de sesión cuando SGI.Identity lo pide (10 minutos, solo para ese usuario). Las reglas, el historial y la reutilización las valida SGI.Identity, y el sistema muestra sus mensajes tal cual. Ninguna de las dos crea sesión.
- **Firmas:** firmar una inspección o resolver una novedad vuelve a validar la contraseña con SGI.Identity y comprueba que los grupos actuales sigan dando un rol que permita esa firma.
- **Tiempo de espera:** `SgiIdentity:TimeoutSegundos` (15 s); pasado, «servicio no disponible».

4.3. Autorización por roles

Los roles se definen en `ECAR.Shared/RolesSistema.cs` y se usan en los atributos `[Authorize(Roles = …)]` de cada ruta; el cliente solo oculta opciones, la protección real está en el servidor. Además de los roles se aplican reglas de propiedad: un Operador solo lee sus inspecciones, evidencias y novedades; solo quien ejecuta una inspección la responde, la firma o le sube fotos.

Tabla 7. Grupos de roles usados en la autorización

Constante	Roles	Uso
`Todos`	Administrador, Operador, Estándar, Supervisor	Consultas de catálogos, tablero, inspecciones y novedades.

Constante	Roles	Uso
`Inspeccionan`	Administrador, Operador, Estándar	Iniciar, responder, subir fotos y firmar.
`Inspectores`	Operador, Estándar	«Mis inspecciones».
`Resuelven`	Administrador, Estándar	Resolver novedades con firma.
`Supervisan`	Administrador, Supervisor	Reportes, auditoría y verificación de integridad.
`Administrador`	Administrador	Catálogos, equipos, checklists, usuarios, roles, anulaciones, desbloqueos y reenvío de correos.

4.4. Protección de las comunicaciones y del navegador

- HTTPS obligatorio (`UseHttpsRedirection`) y HSTS fuera del entorno de desarrollo.
- Cabeceras en todas las respuestas del API: `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: no-referrer` y `Content-Security-Policy: default-src 'none'; frame-ancestors 'none'`.
- CORS: solo los orígenes `localhost` de desarrollo. En producción el cliente y el API comparten origen (el API se publica bajo `/api`), por lo que no se necesita CORS.
- Validación binaria de las fotografías (firma de archivo JPEG `FF D8 FF` o PNG `89 50 4E 47`), además de la extensión y el tamaño máximo.
- Consultas parametrizadas con Entity Framework; las búsquedas no concatenan SQL.
- SGI.Identity: hoy TI lo publica solo por HTTP. El API lo acepta únicamente con `SgiIdentity:PermitirHttp` y lo avisa en el registro en cada arranque, porque las contraseñas viajan sin cifrar entre los dos servidores. Cuando TI publique HTTPS, se cambia la URL, se quita la opción y el servidor debe confiar en el certificado del servicio.

4.5. Secretos

Los secretos nunca van en `appsettings.json`. En desarrollo se usan los *user-secrets* de .NET (`UserSecretsId` del proyecto ECAR.API); en el servidor, variables de entorno o el almacén de secretos de ECAR: `ConnectionStrings__ECARConnection`, `JWT__Secret`, `Firma__ClaveHmac`, `AdminPassword` (solo el primer arranque), `SgiIdentity__ClientId` / `SgiIdentity__ClientSecret` (las credenciales de ECAR en SGI.Identity, que entrega TI; las dos se tratan como confidenciales) y `Correo__Usuario` / `Correo__Password`.

5. Firma electrónica e integridad (CFR 21 Parte 11)

5.1. Firma de una inspección

1. Quien ejecuta la inspección dibuja su firma (PNG de hasta 200 KB) y escribe su contraseña: el API la valida en ese momento con SGI.Identity (reautenticación, §11.200) y comprueba que sus grupos sigan dando un rol que permita firmar. Contraseña errónea: 400. Bloqueada: 423. Vencida, cuenta inactiva o sin rol: 403. Servicio no disponible: 503. En ningún caso se firma. Los intentos fallidos los cuenta SGI.Identity (en las cuentas locales, ECAR: al quinto, 423).
2. El API exige las reglas de cierre: sede elegida, «¿Presenta novedad?» respondida en cada pregunta, observación en cada novedad y checklist con preguntas. Las preguntas Sí/No sin marcar quedan en «No» antes del sello.
3. Guarda el nombre del firmante (el que envía SGI.Identity), la fecha (UTC), el significado («Responsable de la ejecución de la inspección») y el algoritmo, y calcula el sello.
4. En la misma transacción crea una novedad por cada pregunta marcada con «Sí», fija el estado (Cerrada/Satisfactorio o Novedades pendientes/Pendiente), escribe la auditoría y encola el correo.



Figura 2. Flujo funcional de una inspección

5.2. Sello HMAC-SHA256

El sello es un HMAC-SHA256 calculado con la clave `Firma:ClaveHmac`, que vive fuera de la base de datos. La versión vigente, `HMACSHA256-v3`, cubre:

- los datos de la inspección (equipo, checklist, inspector, fechas en *ticks*, observaciones y **sede**);
- cada respuesta (pregunta, respuesta, observación y marca **¿Presenta novedad?**);
- el nombre y el significado de la firma y la imagen de la firma;
- cada fotografía vigente: sus datos y el SHA-256 del archivo. Las retiradas no cuentan.

Las versiones anteriores siguen verificándose con su propia fórmula: `HMACSHA256-v2` (sin sede ni marca de novedad), `HMACSHA256-v1` (incluía el resultado) y `SHA256-v0`. La resolución de cada novedad tiene su propio sello (`CalcularSelloNovedad`), atado al sello de la inspección, que cubre los datos de la novedad, la solución, la firma, el firmante y la fecha de resolución.

5.3. Verificación

`GET /api/inspecciones/{id}/integridad` y `GET /api/novedades/{id}/integridad` (Administrador y Supervisor) recalculan el sello y lo comparan con el guardado: cualquier cambio posterior a la firma (en la base, en una respuesta o en un archivo de foto) se detecta. En pantalla se muestra en la sección «Auditoría criptográfica» del resultado.

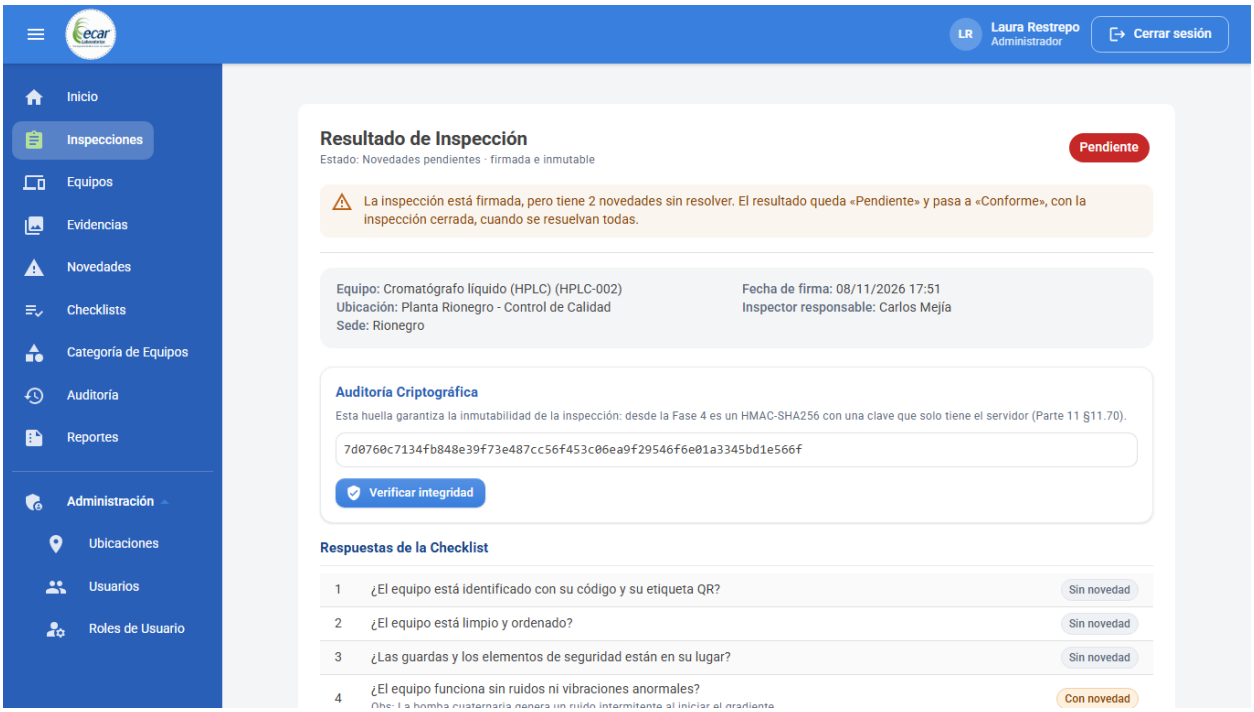


Figura 3. Resultado de una inspección con su sello y el botón Verificar integridad

> **Importante:** Cambiar `Firma:ClaveHmac` invalida la verificación de todas las firmas existentes. La clave se define una sola vez antes de la puesta en marcha y se custodia con respaldo.

5.4. Inmutabilidad y ciclo de vida



Figura 4. Estados de la inspección y de la novedad

- Una inspección firmada no admite cambios de respuestas, sede, fotos ni observaciones (409).
- Solo el Administrador anula una inspección en curso, con motivo. Las novedades pendientes se resuelven o se anulan; una resuelta no se reabre.
- Cuando se resuelve o se anula la última novedad, la inspección pasa a Cerrada/Conforme. Para evitar que dos resoluciones simultáneas la dejen abierta, el cierre bloquea la fila de la inspección (`UPDLOCK, HOLDLOCK`).
- Las tablas `Inspecciones` y `Novedades` tienen control de concurrencia con `RowVersion` (409 si otro usuario la cambió).

6. Auditoría

Toda inserción, modificación o eliminación lógica de las entidades auditadas se registra en la tabla `Auditoria` dentro de la misma transacción del cambio (`ECARDbContext.SaveChangesAsync`): si el cambio se guarda, su auditoría también; si falla, no queda ninguno de los dos.

6.1. Contenido de cada fila

- Tabla, id del registro, acción, valores anterior y nuevo (JSON), usuario (id y «Nombre (usuario)», por ejemplo «Carlos Mejía (cmejia)»), fecha y hora UTC, motivo, dirección IP y agente del navegador.
- **Cadena de huellas:** cada fila guarda `HashAnterior` y su `Hash` = SHA-256 de `HashAnterior|Tabla|RegistroId|Accion|ValorAnterior|ValorNuevo|IdUsuario|FechaHora|Motivo` (fecha con 7 decimales). Alterar o borrar cualquier fila rompe la cadena.

6.2. Acciones registradas

`Crear`, `Modificar`, `Eliminar`, `Desactivar`, `Activar`, `Anular`, `Cerrar`, `Firmar`, `Resolver`, `Retirar`, `LoginExitoso`, `LoginFallido`, `CuentaBloqueada`, `CierreSesion`, `Exportacion`, `VerificacionIntegridad`, `NotificacionEnviada`, `NotificacionFallida`, `CambioPassword` y `Sistema`. `CambioPassword` registra cada cambio de contraseña hecho a través de SGI.Identity (vencida o inicial) con su resultado; `RestablecerPassword` queda solo para registros históricos.

Los inicios de sesión con SGI.Identity guardan el estado que devolvió el servicio y, si se entró, los grupos y los roles. Las altas automáticas y los cambios de nombre o de rol que hace el inicio de sesión quedan con el autor «usuario (SGI.Identity)» y su motivo. Nunca se guardan contraseñas, el `ClientId` ni el número de identificación.

6.3. Protección

El trigger `TR_Auditoria_SoloInsercion` (`INSTEAD OF UPDATE, DELETE`) rechaza cualquier modificación o borrado de la tabla, también por SQL directo. `ECARDbContext` lo declara con `HasTrigger` para que Entity Framework no use `OUTPUT` al insertar. `GET /api/auditoria/verificar` recorre la cadena completa e indica la primera fila alterada, si la hay; `GET /api/auditoria/exportar` genera la copia en PDF o Excel y también queda auditada.

7. Modelo de datos

La base `ECARDB` tiene 14 tablas de negocio más `__EFMigrationsHistory`. El esquema se crea con una sola migración, `20261108184118_EsquemaInicial`, que incluye el trigger de la auditoría.

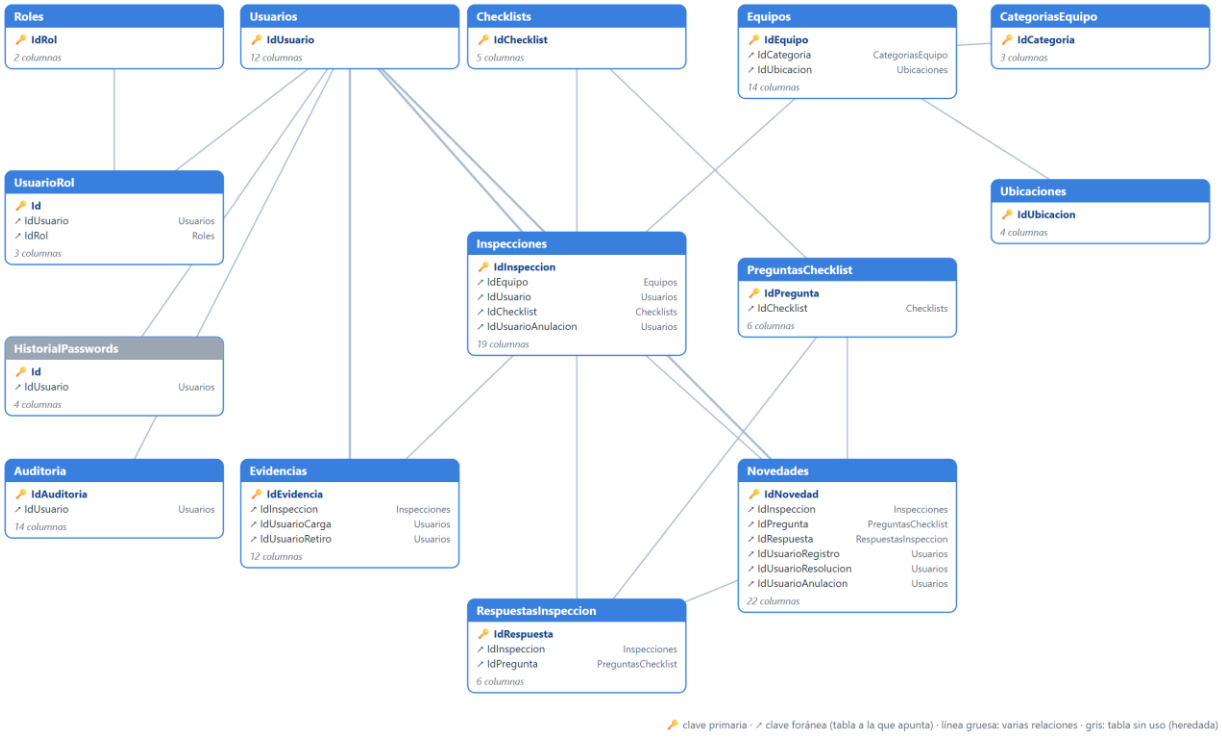


Figura 5. Modelo de datos: tablas, claves primarias y relaciones

Tabla 8. Tablas de la base de datos

Tabla	Columnas	Descripción
`Auditoria`	14	Registro encadenado e inalterable de cambios y eventos.
`CategoriasEquipo`	3	Catálogo de categorías de equipo.
`Checklists`	5	Checklists versionados (nombre + versión únicos).
`Equipos`	14	Inventario de equipos con su token QR.
`Evidencias`	12	Fotografías de las inspecciones (metadatos; el archivo está en disco).
`HistorialPasswords`	4	Tabla heredada sin uso desde el 03/11/2026 (las contraseñas las gestiona SGI.Identity).
`Inspecciones`	19	Inspecciones: estado, resultado, sede, firma y sello.
`Novedades`	22	Novedades creadas al firmar, su resolución firmada o su anulación.
`PreguntasChecklist`	6	Preguntas de cada checklist, con su orden.
`RespuestasInspeccion`	6	Respuestas de cada pregunta, con la marca «¿Presenta novedad?».
`Roles`	2	Roles del sistema.
`Ubicaciones`	4	Catálogo de plantas y áreas.
`UsuarioRol`	3	Asignación de roles a usuarios (un usuario puede tener varios).

Tabla	Columnas	Descripción
`Usuarios`	12	Cuentas de usuario (las de SGI.Identity, sin contraseña local), estado, bloqueo y sello de seguridad.

7.1. Estados y valores controlados

Tabla 9. Valores controlados

Campo	Valores
`Inspecciones.Estado`	`EnCurso`, `NovedadesPendientes`, `Cerrada`, `Anulada` (y `ConNovedad` en registros anteriores a las novedades).
`Inspecciones.Resultado`	`Satisfactorio` (sin novedades), `Pendiente` (con novedades por resolver), `Conforme` (todas resueltas o anuladas).
`Novedades.Estado`	`Pendiente`, `Resuelta`, `Anulada`.
`Equipos.Criticidad`	`Alta`, `Media`, `Baja`.
`Inspecciones.Sede`	`Rionegro`, `Medellín`.
`PreguntasChecklist.TipoRespuesta`	`SiNo` (las nuevas preguntas solo pueden ser de este tipo).

7.2. Diccionario de datos

7.2.1. Auditoria

Columna	Tipo	Nulo	Clave	Descripción
IdAuditoria	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
Tabla	nvarchar(100)	No		
RegistroId	bigint	No		
Accion	nvarchar(50)	No		
ValorAnterior	nvarchar(max)	Sí		Valores anteriores (JSON).
ValorNuevo	nvarchar(max)	Sí		Valores nuevos (JSON).
Usuario	nvarchar(100)	No		
FechaHora	datetime2	No		Fecha y hora (UTC).
IdUsuario	bigint	Sí	FK	Referencia a Usuarios.
Motivo	nvarchar(500)	Sí		Motivo registrado (10–500 caracteres).
DireccionIp	nvarchar(45)	Sí		
AgenteUsuario	nvarchar(300)	Sí		
HashAnterior	char(64)	Sí		
Hash	char(64)	No		SHA-256 de la fila encadenado con el anterior.

7.2.2. CategoriasEquipo

Columna	Tipo	Nulo	Clave	Descripción
IdCategoria	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
Nombre	nvarchar(100)	No		
Descripcion	nvarchar(500)	Sí		

Índices únicos: Nombre.

7.2.3. Checklists

Columna	Tipo	Nulo	Clave	Descripción
IdChecklist	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
Nombre	nvarchar(200)	No		
Version	nvarchar(20)	No		Versión; nombre + versión es único y solo una versión por nombre está activa.
Activo	bit	No		Registro activo o desactivado (baja lógica).
FechaCreacion	datetime2	No		Fecha y hora (UTC).

Índices únicos: Nombre, Version.

7.2.4. Equipos

Columna	Tipo	Nulo	Clave	Descripción
IdEquipo	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
CodigoInterno	nvarchar(50)	No		Código interno único (obligatorio, RN-01).
ActivoFijo	nvarchar(50)	No		Número de activo fijo único (obligatorio, RN-01).
SerialFabricante	nvarchar(100)	Sí		
NombreEquipo	nvarchar(200)	No		
Marca	nvarchar(100)	Sí		
Modelo	nvarchar(100)	Sí		
Fabricante	nvarchar(200)	Sí		
Criticidad	nvarchar(20)	Sí		Alta, Media o Baja.
IdCategoria	bigint	Sí	FK	Referencia a CategoriasEquipo.
IdUbicacion	bigint	Sí	FK	Referencia a Ubicaciones.
QRCode	nvarchar(64)	Sí		Token opaco del código QR (32 caracteres hexadecimales, único).
Activo	bit	No		Registro activo o desactivado (baja lógica).
FechaCreacion	datetime2	No		Fecha y hora (UTC).

Índices únicos: ActivoFijo; CodigoInterno; QRCode (filtrado: QRCode IS NOT NULL).

7.2.5. Evidencias

Columna	Tipo	Nulo	Clave	Descripción
IdEvidencia	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
IdInspeccion	bigint	No	FK	Referencia a Inspecciones.
Archivo	nvarchar(max)	No		Ruta relativa del archivo en la carpeta de evidencias.
NombreOriginal	nvarchar(200)	No		
TipoContenido	nvarchar(100)	No		
TamanoBytes	bigint	No		
FechaCarga	datetime2	No		Fecha y hora (UTC).
IdUsuarioCarga	bigint	No	FK	Referencia a Usuarios.
Retirada	bit	No		Indica si la foto fue retirada (con motivo y usuario).
FechaRetiro	datetime2	Sí		Fecha y hora (UTC).
IdUsuarioRetiro	bigint	Sí	FK	Referencia a Usuarios.
MotivoRetiro	nvarchar(500)	Sí		Motivo registrado (10–500 caracteres).

7.2.6. HistorialPasswords

Columna	Tipo	Nulo	Clave	Descripción
Id	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
IdUsuario	bigint	No	FK	Referencia a Usuarios.
PasswordHash	nvarchar(255)	No		
Fecha	datetime2	No		Fecha y hora (UTC).

7.2.7. Inspecciones

Columna	Tipo	Nulo	Clave	Descripción
IdInspeccion	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
IdEquipo	bigint	No	FK	Referencia a Equipos.
IdUsuario	bigint	No	FK	Referencia a Usuarios.
IdChecklist	bigint	No	FK	Referencia a Checklists.
FechaInspeccion	datetime2	No		Inicio, fijado por el servidor (UTC).
Resultado	nvarchar(50)	Sí		
Observaciones	nvarchar(max)	Sí		
Sede	nvarchar(30)	Sí		
FirmaDigital	nvarchar(max)	Sí		Imagen PNG de la firma (base64).
Estado	nvarchar(20)	No		

Columna	Tipo	Nulo	Clave	Descripción
FechaCierre	datetime2	Sí		Firma (UTC).
FirmaHash	nvarchar(64)	Sí		Sello HMAC-SHA256.
FirmaNombre	nvarchar(200)	Sí		
FirmaSignificado	nvarchar(200)	Sí		Significado de la firma (§11.50).
FirmaAlgoritmo	nvarchar(30)	Sí		Versión del sello (HMACSHA256-v3…).
MotivoAnulacion	nvarchar(500)	Sí		Motivo registrado (10–500 caracteres).
FechaAnulacion	datetime2	Sí		Fecha y hora (UTC).
IdUsuarioAnulacion	bigint	Sí	FK	Referencia a Usuarios.
RowVersion	timestamp	No		Control de concurrencia optimista.

7.2.8. Novedades

Columna	Tipo	Nulo	Clave	Descripción
IdNovedad	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
IdInspeccion	bigint	No	FK	Referencia a Inspecciones.
IdPregunta	bigint	No	FK	Referencia a PreguntasChecklist.
IdRespuesta	bigint	No	FK	Referencia a RespuestasInspeccion.
Descripcion	nvarchar(max)	No		Pregunta y observación que originaron la novedad.
Criticidad	nvarchar(20)	Sí		
Estado	nvarchar(20)	No		
FechaRegistro	datetime2	No		Fecha y hora (UTC).
IdUsuarioRegistro	bigint	No	FK	Referencia a Usuarios.
Solucion	nvarchar(2000)	Sí		Solución registrada al resolver (10–2000 caracteres).
FechaResolucion	datetime2	Sí		Fecha y hora (UTC).
IdUsuarioResolucion	bigint	Sí	FK	Referencia a Usuarios.
FirmaDigital	nvarchar(max)	Sí		
FirmaNombre	nvarchar(200)	Sí		
FirmaSignificado	nvarchar(200)	Sí		
FirmaAlgoritmo	nvarchar(30)	Sí		
FirmaHash	nvarchar(64)	Sí		
MotivoAnulacion	nvarchar(500)	Sí		Motivo registrado (10–500 caracteres).
FechaAnulacion	datetime2	Sí		Fecha y hora (UTC).
IdUsuarioAnulacion	bigint	Sí	FK	Referencia a Usuarios.
FechaNotificacion	datetime2	Sí		Envío del correo a la mesa de ayuda (vacío si no salió).
RowVersion	timestamp	No		

Índices únicos: IdInspeccion, IdPregunta; IdRespuesta.

7.2.9. PreguntasChecklist

Columna	Tipo	Nulo	Clave	Descripción
IdPregunta	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
IdChecklist	bigint	No	FK	Referencia a Checklists.
Pregunta	nvarchar(max)	No		
TipoRespuesta	nvarchar(50)	No		SiNo (o Texto en registros antiguos).
Obligatoria	bit	No		
Orden	int	No		Posición de la pregunta (única por checklist).

7.2.10. RespuestasInspeccion

Columna	Tipo	Nulo	Clave	Descripción
IdRespuesta	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
IdInspeccion	bigint	No	FK	Referencia a Inspecciones.
IdPregunta	bigint	No	FK	Referencia a PreguntasChecklist.
Respuesta	nvarchar(max)	Sí		
Observacion	nvarchar(max)	Sí		
PresentaNovedad	bit	Sí		Marca «¿Presenta novedad?».

Índices únicos: IdInspeccion, IdPregunta.

7.2.11. Roles

Columna	Tipo	Nulo	Clave	Descripción
IdRol	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
Nombre	nvarchar(50)	No		

Índices únicos: Nombre.

7.2.12. Ubicaciones

Columna	Tipo	Nulo	Clave	Descripción
IdUbicacion	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
Planta	nvarchar(100)	No		
Area	nvarchar(100)	No		
Descripcion	nvarchar(300)	Sí		

Índices únicos: Planta, Area.

7.2.13. UsuarioRol

Columna	Tipo	Nulo	Clave	Descripción
Id	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
IdUsuario	bigint	No	FK	Referencia a Usuarios.
IdRol	bigint	No	FK	Referencia a Roles.

Índices únicos: IdUsuario, IdRol.

7.2.14. Usuarios

Columna	Tipo	Nulo	Clave	Descripción
IdUsuario	bigint (identidad)	No	PK	Identificador (clave primaria, autonumérico).
Nombre	nvarchar(200)	No		Nombre de la persona; con SGI.Identity, el que envía en cada inicio de sesión. Es el que queda en las firmas.
Correo	nvarchar(150)	No		Correo único. Para quien entra por SGI.Identity es provisional (`usuario@sgi.local`).
UsuarioAD	nvarchar(100)	Sí		Usuario de SGI.Identity (o del Directorio Activo); único. Enlaza la cuenta con la de SGI.Identity.
PasswordHash	nvarchar(255)	No		Hash BCrypt de una cuenta local; vacío para los usuarios de SGI.Identity.
Activo	bit	No		Registro activo o desactivado (baja lógica).
IntentosFallidos	int	No		Intentos fallidos consecutivos (solo cuentas locales).
BloqueadoHasta	datetime2	Sí		Fin del bloqueo por intentos fallidos (UTC; solo cuentas locales).
FechaCambioPassword	datetime2	Sí		Heredado, sin uso.
DebeCambiarPassword	bit	No		Heredado, sin uso.
SecurityStamp	nvarchar(64)	No		Sello de seguridad; al cambiar, invalida los tokens emitidos.
UltimoAcceso	datetime2	Sí		Último inicio de sesión exitoso (UTC).

Índices únicos: Correo; UsuarioAD (filtrado: UsuarioAD IS NOT NULL).

8. API REST

El API expone 102 rutas en 16 controladores. Todas, salvo las públicas indicadas, requieren el token JWT. En el entorno de desarrollo la especificación OpenAPI está en `/openapi/v1.json` y la documentación interactiva en `/scalar`.

8.1. Rutas por controlador

8.1.1. Auditoria

Método	Ruta	Roles	Descripción
GET	/auditoria	Administrador, Supervisor	Consulta paginada y filtrada de la auditoría.
GET	/auditoria/exportar	Administrador, Supervisor	Exporta la auditoría filtrada (PDF o Excel).
GET	/auditoria/{id}	Administrador, Supervisor	Detalle de una fila.
GET	/auditoria/registro/{tabla}/{registroId}	Administrador, Supervisor	Historial completo de un registro.
GET	/auditoria/verificar	Administrador, Supervisor	Verifica la cadena de huellas.

8.1.2. Auth

Método	Ruta	Roles	Descripción
POST	/auth/login	Público	Inicia sesión (con SGI.Identity) y devuelve el token JWT, el usuario y sus roles; si el servicio pide una acción, 403 con la acción y el pase.
POST	/auth/validate	Público	Valida un token.
GET	/auth/politica	Público	Política de seguridad pública: minutos de inactividad, reglas de las cuentas locales y modo de autenticación (`modoAutenticacion`, `cuentasLocales`).
POST	/auth/password-inicial	Público	Configura la contraseña inicial en SGI.Identity con el pase del inicio de sesión. No crea sesión.
POST	/auth/cambiar-password	Público	Cambia la contraseña vencida (o la que SGI.Identity exige cambiar) con el pase del inicio de sesión. No crea sesión.
POST	/auth/logout	Autenticado	Registra el cierre de sesión en la auditoría.

8.1.3. CategoriasEquipo

Método	Ruta	Roles	Descripción
GET	/categoriasequipo	Todos	Consulta de categorías.
GET	/categoriasequipo/{id}	Todos	Consulta de categorías.
POST	/categoriasequipo	Administrador	Crea categorías.
PUT	/categoriasequipo/{id}	Administrador	Edita categorías.
DELETE	/categoriasequipo/{id}	Administrador	Elimina categorías (no si está en uso).

8.1.4. Checklists

Método	Ruta	Roles	Descripción
GET	/checklists	Todos	Listado de checklists.
GET	/checklists/{id}	Todos	Checklist con sus preguntas.
POST	/checklists	Administrador	Crea un checklist con preguntas.
PUT	/checklists/{id}	Administrador	Edita un checklist sin respuestas (con motivo).
DELETE	/checklists/{id}	Administrador	Desactiva un checklist (con motivo).
PUT	/checklists/{id}/activar	Administrador	Activa una versión (desactiva las demás del mismo nombre).
GET	/checklists/{id}/versiones	Todos	Versiones del mismo checklist.
POST	/checklists/{id}/nueva-version	Administrador	Crea una versión nueva copiando las preguntas.

8.1.5. Dashboard

Método	Ruta	Roles	Descripción
GET	/dashboard	Todos	Indicadores del tablero (desde, hasta, total, planta).
GET	/dashboard/pdf	Todos	Tablero en PDF.
GET	/dashboard/tendencia	Todos	Tendencia por semana o por mes.

8.1.6. Equipos

Método	Ruta	Roles	Descripción
GET	/equipos	Todos	Listado paginado con búsqueda y filtros (planta, área, criticidad).
GET	/equipos/{id}	Todos	Ficha del equipo.
POST	/equipos	Administrador	Crea un equipo y su token QR.
PUT	/equipos/{id}	Administrador	Edita un equipo (con motivo).
DELETE	/equipos/{id}	Administrador	Desactiva un equipo (baja lógica, con motivo).
PUT	/equipos/{id}/activar	Administrador	Reactiva un equipo.
GET	/equipos/categorias	Todos	Categorías para los selectores.
GET	/equipos/ubicaciones	Todos	Ubicaciones para los selectores.
POST	/equipos/{id}/qr	Administrador	Genera el token QR si no existe.
PUT	/equipos/{id}/qr/regenerar	Administrador	Regenera el token QR (el anterior deja de valer).
GET	/equipos/{id}/qr.png	Todos	Imagen PNG del código QR.
GET	/equipos/qr/{token}	Público	Consulta por QR: sin sesión, datos básicos; con sesión, ficha completa y checklists activos.

8.1.7. Evidencias

Método	Ruta	Roles	Descripción
GET	/evidencias	Todos	Listado de evidencias.
GET	/inspecciones/{idInspeccion}/evidencias	Todos	Fotografías de una inspección.
GET	/evidencias/{id}	Todos	Datos de una evidencia.
GET	/evidencias/{id}/archivo	Todos	Archivo de la fotografía.
POST	/inspecciones/{idInspeccion}/evidencias	Administrador, Operador, Estándar	Sube una fotografía (multipart, JPEG/PNG).
POST	/evidencias/{id}/retirar	Administrador, Operador, Estándar	Retira una fotografía de una inspección en curso (con motivo).

8.1.8. Inspecciones

Método	Ruta	Roles	Descripción
GET	/inspecciones	Todos	Listado paginado con búsqueda y estado (el Operador ve solo las suyas).
GET	/inspecciones/mias	Operador, Estándar	Inspecciones del usuario.
GET	/inspecciones/{id}/respuestas	Todos	Respuestas de una inspección.
GET	/inspecciones/{id}	Todos	Detalle de una inspección.
POST	/inspecciones/iniciar	Administrador, Operador, Estándar	Inicia (o retoma) una inspección de un equipo con un checklist.
GET	/inspecciones/{id}/ejecucion	Todos	Estado de la ejecución: preguntas, respuestas, fotos y contadores.
POST	/inspecciones	Administrador	Alta directa de una inspección (Administrador).
PUT	/inspecciones/{id}	Administrador, Operador, Estándar	Edita las observaciones de una inspección en curso.
PUT	/inspecciones/{id}/respuestas	Administrador, Operador, Estándar	Guarda respuestas, marcas de novedad y observaciones.
PUT	/inspecciones/{id}/sede	Administrador, Operador, Estándar	Fija la sede (Rionegro o Medellín).
POST	/inspecciones/{id}/anular	Administrador	Anula una inspección en curso (con motivo).
POST	/inspecciones/{id}/firmar	Administrador, Operador, Estándar	Firma con firma dibujada y contraseña; sella y crea las novedades.
GET	/inspecciones/{id}/registro.pdf	Todos	Registro de la inspección en PDF.
GET	/inspecciones/{id}/integridad	Administrador, Supervisor	Verifica el sello de la inspección.
GET	/inspecciones/{id}/resultado	Todos	Resultado completo de una inspección firmada.

8.1.9. Novedades

Método	Ruta	Roles	Descripción
GET	/novedades	Todos	Listado con filtros (estado, criticidad, equipo, inspección, fechas).
GET	/novedades/{id}	Todos	Detalle de una novedad.
POST	/novedades/{id}/resolver	Administrador, Estándar	Resuelve con solución, firma y contraseña.

Método	Ruta	Roles	Descripción
POST	/novedades/{id}/anular	Administrador	Anula una novedad pendiente (con motivo).
GET	/novedades/{id}/integridad	Administrador, Supervisor	Verifica el sello de la resolución.
POST	/novedades/{id}/notificar	Administrador	Reenvía el correo de la inspección de la novedad.

8.1.10. PreguntasChecklist

Método	Ruta	Roles	Descripción
GET	/preguntaschecklist	Todos	Listado paginado de preguntas.
GET	/preguntaschecklist/checklist/{idChecklist}	Todos	Preguntas de un checklist.
POST	/preguntaschecklist	Administrador	Agrega una pregunta.
PUT	/preguntaschecklist/{id}	Administrador	Edita una pregunta sin respuestas.
DELETE	/preguntaschecklist/{id}	Administrador	Elimina una pregunta sin respuestas.

8.1.11. Reportes

Método	Ruta	Roles	Descripción
GET	/reportes/usuarios	Administrador, Supervisor	Búsqueda de usuarios para el filtro de reportes (id, nombre, usuario y correo).
GET	/reportes/historial-equipo	Administrador, Supervisor	Historial por equipo (json, pdf o xlsx).
GET	/reportes/historial-area	Administrador, Supervisor	Historial por área.
GET	/reportes/historial-usuario	Administrador, Supervisor	Historial por usuario.
GET	/reportes/equipos-novedades	Administrador, Supervisor	Equipos con novedades.
GET	/reportes/inspecciones-fechas	Administrador, Supervisor	Inspecciones por fechas (totales, satisfactorias, con novedad).

8.1.12. RespuestasInspeccion

Método	Ruta	Roles	Descripción
GET	/respuestasinspeccion	Todos	Consulta de respuestas por inspección.

8.1.13. Roles

Método	Ruta	Roles	Descripción
GET	/roles	Administrador	Listado de roles.
GET	/roles/{id}	Administrador	Detalle de un rol.
POST	/roles	Administrador	Crea un rol.
PUT	/roles/{id}	Administrador	Renombra un rol (no los del sistema).
DELETE	/roles/{id}	Administrador	Elimina un rol (no los del sistema).

8.1.14. Ubicaciones

Método	Ruta	Roles	Descripción
GET	/ubicaciones	Todos	Consulta de ubicaciones.
GET	/ubicaciones/{id}	Todos	Consulta de ubicaciones.
POST	/ubicaciones	Administrador	Crea ubicaciones.
PUT	/ubicaciones/{id}	Administrador	Edita ubicaciones.
DELETE	/ubicaciones/{id}	Administrador	Elimina ubicaciones (no si está en uso).

8.1.15. Usuarios

Método	Ruta	Roles	Descripción
GET	/usuarios	Administrador	Listado de usuarios.
GET	/usuarios/{id}	Administrador	Detalle de un usuario.
POST	/usuarios	Administrador	Registra un usuario con al menos un rol; con SGI.Identity, sin contraseña y con su usuario de SGI.Identity.
PUT	/usuarios/{id}	Administrador	Edita nombre, correo, usuario y roles (sin contraseña); con SGI.Identity, el nombre y los roles vuelven a los del servicio en el siguiente ingreso.
DELETE	/usuarios/{id}	Administrador	Desactiva un usuario (con motivo) e invalida sus sesiones.
PUT	/usuarios/{id}/activar	Administrador	Reactiva un usuario.
POST	/usuarios/{id}/desbloquear	Administrador	Desbloquea una cuenta local (con motivo).

8.1.16. UsuariosRol

Método	Ruta	Roles	Descripción
GET	/usuariosrol	Administrador	Asignaciones de roles.
GET	/usuariosrol/{id}	Administrador	Detalle de una asignación.
POST	/usuariosrol	Administrador	Asigna un rol a un usuario.
PUT	/usuariosrol/{id}	Administrador	Cambia una asignación (no deja a nadie sin rol).
DELETE	/usuariosrol/{id}	Administrador	Quita una asignación (no la única de un usuario).
GET	/usuariosrol/usuarios	Administrador	Usuarios para el selector.
GET	/usuariosrol/roles	Administrador	Roles para el selector.

> **Nota:** Las rutas de preguntas de checklist y de respuestas se conservan por compatibilidad, pero la interfaz ya no tiene pantallas propias para ellas: las preguntas se editan dentro del checklist y las respuestas se ven en el resultado de la inspección.

9. Cliente: ECAR.Client (Blazor WebAssembly)

9.1. Estructura

Tabla 10. Estructura del cliente

Carpeta	Contenido
`Pages/`	Pantallas con ruta: tablero (`Home`), equipos, inspecciones (iniciar, ejecutar, resultado), novedades, evidencias, checklists, categorías, ubicaciones, reportes, auditoría, consulta QR, login, cambio de contraseña y activación de la cuenta (`CambiarPassword`, `ActivarCuenta`) y `Admin/` (usuarios y asignación de roles).
`Components/`	Diálogos y piezas reutilizables: modales de alta y edición, `PasoPreguntas`, `PasoEvidencias`, `PasoFirma`, `FirmaCanvas`, `ConfirmarIdentidadDialog`, `MotivoDialog`, `EscanerQrDialog`, `VisorImagenDialog`, `BuscadorMultiple`, `TarjetaAcceso` (tarjeta de las pantallas de acceso), guardas de ruta y `VigilanteSesion`.
`Services/`	`HttpClientService` (todas las llamadas al API; nunca devuelve null y su mensaje se puede mostrar tal cual), `LectorRespuestaApi`, `AuthService`, `AuthorizationService`, `SesionService`, `SesionExpiradaHandler`, `CambioPasswordEstado`, formateadores y `LocalizadorMud` (textos de MudBlazor en español).
`Layout/`	`MainLayout` (barra, menú por rol), `EmptyLayout` y el tema `TemaEcar`.
`wwwroot/`	`index.html`, estilos (`styles/theme.css`, `css/print-resultado.css`), logo e íconos, `lib/html5-qrcode` y los módulos JavaScript.

9.2. Interoperabilidad con JavaScript

Tabla 11. Módulos JavaScript del cliente

Archivo	Función
`js/firma.js`	Lienzo de la firma dibujada (eventos de puntero, táctil y ratón) y exportación a PNG.
`js/escaner-qr.js`	Lectura de códigos QR con la cámara (html5-qrcode).
`js/etiqueta-qr.js`	Impresión de la etiqueta QR en un iframe aparte.
`js/visor-imagen.js`	Zoom con rueda, botones, pellizco, arrastre y doble clic en el visor de evidencias.
`js/descargas.js`	Descarga de archivos (PDF, Excel, PNG) generados por el API.
`js/actividad.js`	Detección de actividad para el cierre por inactividad.
`js/formularios.js`	Enter pasa al campo siguiente en los formularios.

9.3. Dirección del API y sesión

- Si la página se abre desde `localhost`, el cliente llama al API en `https://localhost:7296`; desde cualquier otra dirección, lo busca en el mismo origen (`/api`). La clave `ApiBaseUrl` de `wwwroot/appsettings.json`, si existe, manda sobre ambas.
- El token se guarda en el almacenamiento del navegador. `SesionExpiradaHandler` detecta un 401 en una petición autenticada, cierra la sesión y vuelve al login conservando la página (solo rutas propias).

- `VigilanteSesion` cierra la sesión tras los minutos de inactividad que publica el API.
- Cuando el inicio de sesión responde con una acción de SGI.Identity, el cliente guarda el pase solo en memoria (`CambioPasswordEstado`) y abre `/cambiar-password` o `/activar-cuenta`; entrando por la URL o recargando, esas pantallas vuelven al login. Al terminar, el login muestra el aviso (`?aviso=password-cambiada` o `cuenta-activada`).
- Las guardas `AdminRouteGuard`, `InspectorRouteGuard` y `RolRouteGuard` redirigen según el rol; las páginas comprueban el rol antes de llamar al API. La protección real está en el servidor.

9.4. Diseño y adaptación a pantallas

El tema corporativo usa el azul `#397FDE` como color primario. Las tablas se apilan como tarjetas por debajo de 960 o 1280 px según su ancho, la columna de acciones queda fija a la derecha y todas las pantallas se revisaron a 1366, 1024, 768 y 375 px sin desbordes horizontales.

10. Procesos clave

10.1. Inspección

1. `POST /api/inspecciones/iniciar` con equipo y checklist activos (409 con la existente si ya hay una en curso).
2. `GET …/ejecucion` carga preguntas, respuestas y fotos; `PUT …/respuestas` guarda cada cambio; `PUT …/sede` fija la sede.
3. `POST /api/inspecciones/{id}/evidencias` sube cada foto; `POST /api/evidencias/{id}/retirar` la retira con motivo.
4. `POST …/firmar` valida, sella, crea las novedades y encola el correo; `GET …/resultado` y `GET …/registro.pdf` muestran el resultado.

10.2. Novedades y notificaciones

Al firmar una inspección con novedades se encola su id en `ColaNotificaciones`. `EnvioNotificacionesService` (servicio en segundo plano) arma un único correo con todas las novedades de la inspección y lo envía por SMTP a `Correo:Destinatarios`. Si no hay `Correo:Usuario` y `Correo:Password`, guarda el mensaje como `.eml` en `Correo:CarpetaSalida` y la novedad queda «sin enviar» para reenviarla después (`POST /api/novedades/{id}/notificar`). Un fallo de correo no revierte la firma; cada envío o fallo queda en la auditoría.

10.3. Reportes y tablero

- Un endpoint por reporte con `formato=json|pdf|xlsx`. Fechas obligatorias, máximo un año y 10 000 filas por archivo; las columnas son las del SRS §7 más la sede.
- Los filtros de varios valores se envían repitiendo la clave en la URL (`?plantas=A&plantas=B`).
- El tablero agrupa la tendencia por semana en periodos de hasta 92 días (`DiasMaximosPorSemana`) y por mes en periodos más largos o con `total=true`.

10.4. Código QR

Al crear un equipo se genera un token opaco de 32 caracteres hexadecimales (índice único filtrado). El código QR codifica `{Cliente:BaseUrl}/equipos/qr/{token}`: sin sesión, la consulta devuelve solo nombre, código interno, ubicación y checklists activos; con sesión, la ficha completa. Regenerar el token invalida la etiqueta anterior.

10.5. Evidencias

Se aceptan JPEG y PNG hasta `Evidencias:TamanoMaximoMB` (5 MB), validados por su firma binaria. El archivo se guarda con un nombre GUID en `{RutaBase}/{año}/{mes}/{idInspección}/` y su SHA-256 entra en el sello de la inspección al firmar.

11. Configuración

`ECAR.API/appsettings.json` contiene los valores generales; los secretos (incluidos el `ClientId` y el `ClientSecret` de SGI.Identity) se dan por variables de entorno (el separador `:` se escribe `__`) o por el almacén de secretos.

Tabla 12. Claves de configuración del API

Clave	Valor por defecto	Descripción
`ConnectionStrings:ECARConnection`	(secreto)	Cadena de conexión a SQL Server. Obligatoria.
`JWT:Secret`	(secreto)	Clave de firma de los tokens; 32 caracteres o más. Obligatoria.
`JWT:Issuer` / `JWT:Audience`	ECAR-Auditoria / ECAR-Users	Emisor y audiencia del token.
`JWT:ExpirationHours`	8	Vigencia del token en horas.
`Firma:ClaveHmac`	(secreto)	Clave de los sellos HMAC; 32 caracteres o más. Obligatoria y fija.
`AdminPassword`	(secreto)	Contraseña del administrador inicial `admin@ecar.com` en el primer arranque.
`Seguridad:LongitudMinimaPassword`	10	Longitud mínima de la contraseña del alta de una cuenta local.
`Seguridad:RequiereLetrasYNumeros`	true	Exige letras y números en esa contraseña.
`Seguridad:MaxIntentosFallidos`	5	Intentos fallidos antes del bloqueo (cuentas locales).
`Seguridad:MinutosBloqueo`	30	Duración del bloqueo (cuentas locales).
`Seguridad:MinutosInactividad`	15	Cierre de sesión por inactividad en el cliente.
`ECARAuthentication:Mode`	SgiIdentity	SgiIdentity (vigente). Local, ActiveDirectory e Hybrid quedan como contingencia.
`SgiIdentity:BaseUrl`	(vacío)	URL de SGI.Identity tal como la entrega TI. Obligatoria en el modo SgiIdentity.
`SgiIdentity:PermitirHttp`	false	Admite una URL `http://`; el API lo avisa en el registro en cada arranque. Solo mientras TI no publique HTTPS.
`SgiIdentity:ClientId` / `ClientSecret`	(secreto) / (secreto)	Credenciales de ECAR en SGI.Identity, por ambiente. Nunca en `appsettings`.
`SgiIdentity:Grupos`	{}	Grupo de SGI.Identity → rol de ECAR. Vacío: un grupo que se llame como el rol (sin distinguir mayúsculas ni tildes) da ese rol.
`SgiIdentity:PermitirCuentasLocales`	true	Las cuentas con contraseña en ECAR (`admin@ecar.com`) siguen entrando como respaldo.
`SgiIdentity:CrearUsuariosAlEntrar`	true	El primer inicio de sesión registra al usuario; con false, el Administrador debe registrarlo antes.
`SgiIdentity:TimeoutSegundos` / `DominioCorreo` / `MinutosPaseCambioPassword`	15 / sgi.local / 10	Espera de cada llamada, dominio del correo provisional y vigencia del pase de cambio o activación.
`ActiveDirectory:Enabled` / `Server` / `Port` / `Domain` / `UseSsl` / `TimeoutSeconds`	false / — / 636 / — / true / 10	Conexión LDAP al Directorio Activo (modos alternativos).
`Cliente:BaseUrl`	https://localhost:7267	Dirección pública de la aplicación (etiquetas QR y enlaces del correo). Se fija al desplegar.
`Correo:Habilitado`	true	false apaga las notificaciones.

Clave	Valor por defecto	Descripción
`Correo:Servidor` / `Puerto` / `UsarSsl`	smtp.gmail.com / 587 / true	Servidor SMTP (STARTTLS).
`Correo:Usuario` / `Password` / `Remitente` / `NombreRemitente`	(secreto) / (secreto) / — / ECAR - Inspecciones	Cuenta que envía el aviso.
`Correo:Destinatarios`	dirección de pruebas	Lista de destinatarios (mesa de ayuda). Se fija al desplegar.
`Correo:CarpetaSalida` / `SegundosEspera`	CorreosSalida / 30	Carpeta de los .eml sin credenciales y tiempo máximo del envío SMTP.
`Evidencias:RutaBase`	EvidenciasStorageLocal	Carpeta de las fotos; en producción, ruta absoluta fuera de la aplicación.
`Evidencias:TamanoMaximoMB` / `TiposPermitidos`	5 / image/jpeg, image/png	Límites de las fotos.
`Logging:LogLevel`	Information	Nivel de registro; en producción conviene `Microsoft.EntityFrameworkCore` en Warning.
`ASPNETCORE_FORWARDEDHEADERS_ENABLED`	(sin definir)	Variable de entorno; `true` detrás de un proxy inverso, para que la auditoría registre la IP del usuario (`X-Forwarded-For`).

12. Instalación y despliegue

El SRS v1.1 no fija el servidor web. Esta sección describe un despliegue de referencia con IIS; sirve cualquier servidor que publique los archivos estáticos del cliente y reenvíe `/api` al API en el mismo origen (proxy inverso). El paso a paso, con los comandos para generar las claves y lo que se edita, está en la **Guía de primer inicio en el servidor**.

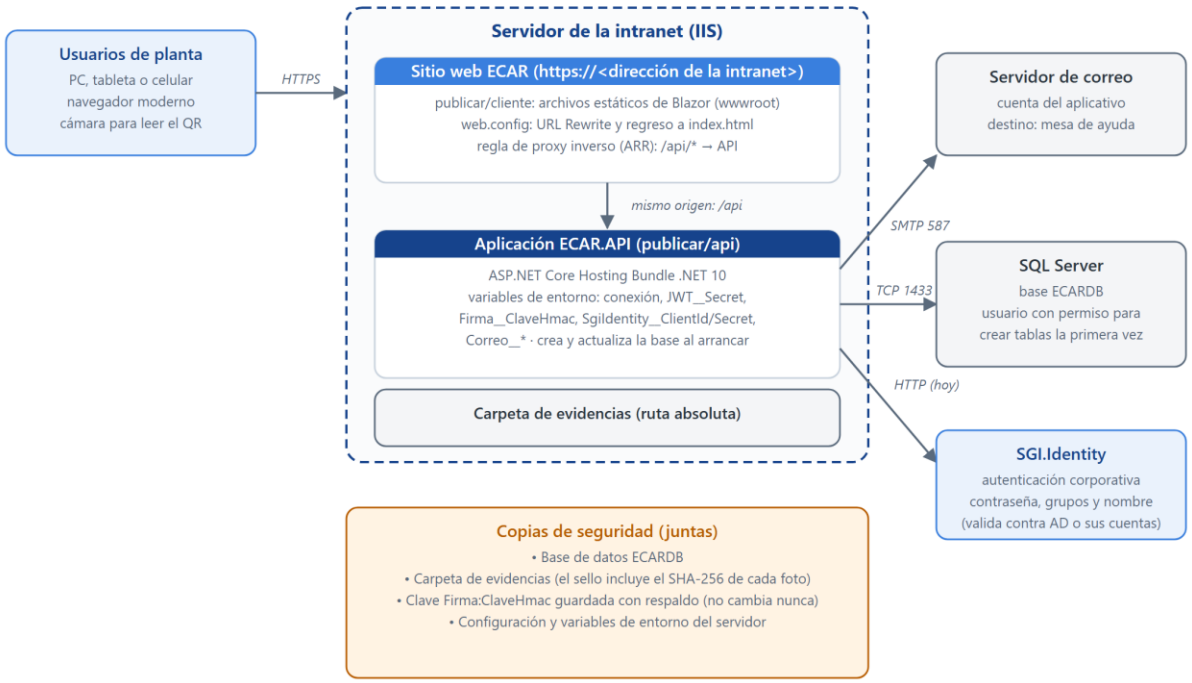


Figura 6. Despliegue de referencia en la intranet de ECAR (IIS)

12.1. Requisitos del servidor

- Windows Server con IIS, el *ASP.NET Core Hosting Bundle* de .NET 10, los módulos *URL Rewrite* y *Application Request Routing* (ARR).
- SQL Server 2022 accesible desde el servidor web; un usuario con permiso para crear tablas en el primer arranque (después basta con lectura y escritura).
- Certificado HTTPS para la dirección de la intranet (necesario también para usar la cámara del celular).
- Acceso al servidor SMTP de ECAR y a SGI.Identity (hoy por HTTP).

12.2. Compilación y publicación

```
dotnet publish ECAR.API -c Release -o publicar/api
dotnet publish ECAR.Client -c Release -o publicar/cliente
```

12.3. Configuración en IIS

1. Crear el sitio de la aplicación con la carpeta `publicar/cliente` como ruta física y el certificado HTTPS. Su `web.config` sirve los archivos de `wwwroot` y devuelve `index.html` en las rutas de la aplicación.
2. Instalar el API (`publicar/api`) como aplicación ASP.NET Core en un puerto interno, con las variables de entorno de la tabla de configuración en el grupo de aplicaciones.
3. En el sitio, agregar una regla de proxy inverso (ARR) que envíe `/api/*` al API, antes de las reglas del `web.config` del cliente.
4. Agregar `ASPNETCORE_FORWARDEDHEADERS_ENABLED=true` a las variables del API: detrás del proxy, sin ella la auditoría registra la IP del propio servidor (`127.0.0.1`) en lugar de la del usuario. El API debe escuchar solo en `127.0.0.1` para que nadie más pueda enviarle esa cabecera.
5. Fijar `Cliente__BaseUrl` con la dirección pública y `Evidencias__RutaBase` con una ruta absoluta; dar permisos de escritura al grupo de aplicaciones sobre esa carpeta y la de los `.eml`.
6. Configurar SGI.Identity: `SgiIdentity__ClientId` y `SgiIdentity__ClientSecret` como variables del API, y en `appsettings.Production.json` la URL, `PermitirHttp` (mientras la URL sea http) y la tabla `Grupos` con los nombres reales.

12.4. Base de datos

En el primer arranque el API aplica la migración `EsquemaInicial`, crea el trigger de la auditoría y siembra los cuatro roles y el administrador `admin@ecar.com`. No se siembran catálogos ni datos de ejemplo. Si el DBA prefiere aplicar el esquema a mano:

```
dotnet build
dotnet ef migrations script --idempotent --project ECAR.Infrastructure --startup-project
ECAR.API -o esquema.sql
```

12.5. Verificación después del despliegue

- Abrir la dirección de la intranet: debe mostrarse la pantalla de inicio de sesión.
- Iniciar sesión con `admin@ecar.com` y luego con un usuario de SGI.Identity de cada grupo: cada uno entra con su nombre y el rol de su grupo.
- Crear las categorías, ubicaciones y checklists de ECAR.
- Crear un equipo, imprimir su etiqueta y leerla con la cámara de un celular.
- Ejecutar una inspección de prueba con una novedad y una foto, firmarla y comprobar el correo (o el .eml) y la verificación de integridad.
- Revisar la auditoría y **Verificar integridad**.

13. Operación y mantenimiento

13.1. Copias de seguridad

Respaldar **juntas** la base `ECARDB` y la carpeta de evidencias: el sello de cada inspección incluye el SHA-256 de sus fotos, de modo que restaurar la base sin las fotos (o con otras) hace fallar su verificación. Guardar también `Firma:ClaveHmac` en un lugar seguro con respaldo y la configuración del servidor.

13.2. Registros y monitoreo

- El API escribe su registro con `Microsoft.Extensions.Logging` (consola o el destino que configure IIS). Los fallos de correo y de verificación quedan además en la auditoría.
- Los eventos de seguridad (inicios de sesión, fallos, bloqueos y cierres) se consultan en **Auditoría** filtrando por acción. El detalle de un inicio fallido por falta de grupo muestra los grupos que envió SGI.Identity.
- El registro avisa en cada arranque si SGI.Identity se consulta por HTTP, y registra como error cuando el servicio rechaza a ECAR (ClientId o ClientSecret), sin escribir las credenciales.

13.3. Rotación de claves

- `JWT:Secret` se puede cambiar: solo obliga a todos a iniciar sesión de nuevo.
- `Firma:ClaveHmac` **no** se cambia: las firmas existentes dejarían de verificarse.
- Las credenciales de la base y del correo se rotan según la política de ECAR, actualizando las variables de entorno.
- El `ClientId` y el `ClientSecret` de SGI.Identity los rota TI: se actualizan sus variables y se reinicia el API. Si alguno se expone, se pide su rotación.

13.4. Cambios en el modelo de datos

La línea base del esquema es la migración `EsquemaInicial`. Un cambio de modelo se agrega con una migración nueva desde esta misma solución; el API la aplica al arrancar:

```
dotnet ef migrations add <NombreDelCambio> --project ECAR.Infrastructure --startup-project
ECAR.API
dotnet ef migrations has-pending-model-changes --project ECAR.Infrastructure --startup-
project ECAR.API
```

> **Importante:** Esta entrega reemplazó el historial de migraciones del desarrollo por una sola migración. Una base creada con esta versión no reconoce las migraciones del repositorio de desarrollo: las actualizaciones deben partir de esta misma línea base.

13.5. Dependencias y licencias

- No actualizar PDFsharp-MigraDoc a la versión 6.5 o posterior: cambió a licencia AGPL-3.0 y exige licencia comercial.

- En MigraDoc 6, la orientación horizontal se fija con `PageWidth`/`PageHeight` (así lo hace `ExportadorTabla.Documento`).
- La librería html5-qrcode (Apache-2.0) se sirve desde `wwwroot/lib/html5-qrcode` con su `LICENSE`, sin CDN, porque la planta puede no tener salida a internet.
- La interfaz carga la fuente Roboto de Google Fonts; sin internet se usa la fuente del sistema.
- SGI.Identity: el contrato seguido es el de su guía de integración y su documento de arquitectura v1.0 (10/11/2026). Un estado nuevo o desconocido cuenta como «no disponible» (no se entra); si TI cambia el contrato, hay que revisar `SgiIdentityClient`.

13.6. Datos heredados sin uso

La tabla `HistorialPasswords` y las columnas `Usuarios.DebeCambiarPassword` y `Usuarios.FechaCambioPassword` se conservan en el modelo por compatibilidad, pero no se usan desde que la gestión de contraseñas pasó a un servicio externo (03/11/2026), hoy SGI.Identity. Se pueden retirar con una migración futura.

14. Pruebas y calidad

El repositorio de desarrollo mantiene las pruebas automatizadas (no forman parte de la copia de entrega). La integración con SGI.Identity se probó sobre esta copia de entrega, con un simulador que implementa el contrato del servicio:

Tabla 13. Evidencias de pruebas

Tipo	Alcance	Resultado (08/11/2026)
Pruebas del API (xUnit, base en memoria)	Reglas de negocio, permisos por rol, firma, integridad, auditoría, reportes, cuentas	347 superadas
Pruebas de integración (SQL Server real)	Trigger, concurrencia, transacciones, filtros y verificación sobre SQL Server	46 superadas
Batería HTTP de punta a punta	Autenticación, permisos, catálogos, inspección completa, novedades, reportes, tablero, auditoría y entradas inválidas	207 de 207
Revisión de pantallas	19 rutas a 1366, 1024, 768 y 375 px	Sin desbordes ni errores de consola
Verificación de la copia de entrega	Esquema de la migración única frente al de las 13 migraciones; API publicado en producción sobre base nueva	Esquema equivalente; 207 de 207
Integración con SGI.Identity (10/11/2026)	Inicio de sesión y sus estados, alta automática, nombre, roles por grupos, cambio y activación, firmas, caídas y rechazo del servicio, credenciales fuera de los registros y de la auditoría	134 de 134; opciones 9 de 9; arranque 6 de 6
Guía de primer inicio (10/11/2026)	API publicado en producción con la configuración de la guía, detrás del proxy	12 de 12

> **Importante:** La integración no se probó contra SGI.Identity real: al cierre de esta versión no había credenciales de un ambiente de pruebas. Se probará en la UAT.

Anexo A. Comandos útiles

```
# Compilar la solución
dotnet build ECAR.AuditoriaEquipos.slnx

# Secretos en un equipo de desarrollo
dotnet user-secrets set "ConnectionStrings:ECARConnection"
"Server=.\SQLEXPRESS;Database=ECARDB;Trusted_Connection=True;TrustServerCertificate=True" -
-project ECAR.API
dotnet user-secrets set "JWT:Secret" "<texto aleatorio de 32 caracteres o más>" --project
ECAR.API
dotnet user-secrets set "Firma:ClaveHmac" "<texto aleatorio de 32 caracteres o más>" --
project ECAR.API
dotnet user-secrets set "AdminPassword" "<contraseña inicial del administrador>" --project
ECAR.API
dotnet user-secrets set "SgiIdentity:ClientId" "<ClientId de ECAR>" --project ECAR.API
dotnet user-secrets set "SgiIdentity:ClientSecret" "<ClientSecret de ECAR>" --project
ECAR.API

# Ejecutar en local (dos consolas)
dotnet run --project ECAR.API --launch-profile https      # https://localhost:7296
dotnet run --project ECAR.Client --launch-profile https   # https://localhost:7267
```

Anexo B. Glosario técnico

Término	Definición
DTO	Objeto de transferencia de datos entre el cliente y el API.
EF Core	Entity Framework Core, el mapeador objeto-relacional de .NET.
HMAC-SHA256	Código de autenticación de mensajes con clave secreta y la función SHA-256.
JWT	JSON Web Token: credencial firmada que identifica al usuario en cada petición.
Migración	Script versionado que crea o modifica el esquema de la base de datos.
Proxy inverso	Componente del servidor web que reenvía ciertas rutas (aquí, `/api`) a otra aplicación.
SecurityStamp	Valor aleatorio por usuario que, al cambiar, invalida sus tokens.
SGI.Identity	Servicio corporativo de autenticación de ECAR: valida usuarios y contraseñas y entrega el nombre y los grupos de cada persona.
ClientId / ClientSecret	Credenciales con las que ECAR se identifica ante SGI.Identity (autenticación Basic).
SPA	Aplicación de una sola página que se ejecuta en el navegador.